

JuiceBox Retail Pvt. Ltd.

4th Floor, Orion Tech Park, Whitefield, Bengaluru, Karnataka 560066

Document	Request for Security Assessment Services (RFP and Statement of Work)
Engagement reference	JB/SEC/2026/026
Date of issue	10 September 2026
Issued to	EPCET Security Research Laboratory — Semi-Autonomous Red Teaming Team
Primary client contact	Ananya Rao — Chief Information Security Officer ciso.office@juiceboxretail.example +91 80 4XXX 2100 (ext. 401)
Test window	11 September 2026 to 17 September 2026 (both days inclusive)
Classification	Confidential — Client and Assessment Team only

1. Cover letter from the client

Dear EPCET Security Research Laboratory — Semi-Autonomous Red Teaming Team,

JuiceBox Retail Pvt. Ltd. ("JuiceBox", "the Company") has deployed a self-hosted AI gateway (the open-source OmniRoute platform) as shared infrastructure for its engineering organisation: a single OpenAI-compatible endpoint through which the Company's development tools reach external AI providers, holding provider API keys, per-key spend quotas and usage-audit records. Under engagement JB/SEC/2026/022 your team performed the second-pass deep assessment of the container-based laboratory deployment of the former storefront. For this engagement the Company requires an assessment of the gateway as it actually runs in production — a real, unmodified third-party application, not a deliberately weakened training target — because the gateway is about to be opened to the branch-office engineering teams. The assessment is conducted from a dedicated attacker virtual machine (a full Kali Linux system operated by your semi-autonomous framework), directed across the laboratory network at the gateway host, so that the assessment exercises a real attacker system, real kernels and real network paths against a real application. The Company now requires full service and version enumeration, a complete HTTP security-header audit, technology fingerprinting, cookie and transport review, and rate-limited template-driven vulnerability checks, all correlated into one prioritized report. The Company specifically requires that the executed commands demonstrably originate from the attacker virtual machine, with per-step evidence of the machine that ran them, as this report is the evidence the CISO office requires before the widened exposure is approved.

We request your team to perform a non-destructive external and web-application security assessment of the assets identified in Section 3 of this document, strictly within the authorized scope stated therein, during the test window stated above. We understand that your assessment methodology is semi-autonomous: automated reconnaissance and scanning steps are proposed by your framework and must be individually reviewed and approved by your human operator before execution. This is acceptable to the Company, and we specifically require that this human approval step remain in force for every command issued against our assets. The Company also asks that the final report quantify the coverage achieved relative to the manual effort an unaided tester would have required, as described in Section 6.

All systems listed in Section 3 are owned or controlled by the Company. No third-party, shared-hosting, or cloud-provider infrastructure is included in scope. Please sign and return the authorization in Section 8 to confirm your acceptance of these terms.

Yours sincerely,

Ananya Rao
Chief Information Security Officer
JuiceBox Retail Pvt. Ltd.

2. Background and business context

JuiceBox Retail operates a loyalty and retail platform serving approximately 240,000 registered customers, and its engineering organisation of 180 developers uses AI coding assistants and model APIs daily. To keep that usage governed, the Company self-hosts an AI gateway — the open-source OmniRoute platform, a Node.js/Next.js web application with a dashboard and an OpenAI-compatible API — so that every model request flows through one Company-controlled endpoint with provider keys, per-key spend quotas and an audit trail. The gateway is real production software, run unmodified exactly as published by its upstream project.

The gateway currently serves the head-office engineering VLAN. Before it is opened to the branch offices, the CISO office requires an independent security assessment of the deployment as it actually runs. To make that assessment representative, the Company has built an assessment virtualization laboratory on the laboratory network (192.168.198.0/24): the production gateway deployment is staged on the laboratory application host there, and the assessment itself is conducted from a dedicated attacker virtual machine — a full Kali Linux system whose terminal the assessment framework operates directly — so the assessment exercises a genuine attacker platform, real network paths and a real application, rather than single-purpose training targets. The assessment requested here covers that deployment and is the evidence the CISO office requires before the widened exposure is approved.

3. Authorized scope of the assessment

3.1 Primary asset — self-hosted AI gateway (in scope, deep assessment)

The following asset is the only application system authorized for this engagement. All testing activity must be directed exclusively at it.

Attribute	Value
System name	Self-hosted AI gateway (OmniRoute)
Authorized target address	192.168.198.86:20128 (virtualization laboratory)
Authorized scope identifiers	192.168.198.86, 192.168.198.86:20128
Technology	Node.js / Next.js self-hosted AI gateway (OmniRoute) with an OpenAI-compatible API and a web dashboard, HTTP on TCP port 20128
Asset criticality (client-declared, 0-100)	90 — production gateway holding provider API keys, spend quotas and usage-audit records; compromise would expose provider credentials
Assessment type	Deep external and web-application assessment (full framework toolset, subject to Section 5.3)
Verification endpoints	/v1/chat/completions (the gateway's OpenAI-compatible completion endpoint; a bounded proof-of-concept payload is authorized here under Section 5.2)
Environment	The Company's production gateway deployment, staged on the laboratory application host and reachable from the attacker VM across the laboratory network; the software is run unmodified as published by the upstream project

3.2 Network segment — laboratory virtualization range (in scope, discovery sweep only)

To confirm that no unmanaged service is exposed on the isolated laboratory network, the Company additionally authorizes a network-level discovery sweep of the segment below. This authorization is strictly limited to host and service discovery: application-layer inspection of any system found on the segment requires a separate authorization naming that system.

Attribute	Value
System name	Virtualization lab segment
Authorized target address	192.168.198.0/24 (laboratory network)

Attribute	Value
Authorized scope identifiers	192.168.198.0/24
Technology	Laboratory network carrying the attacker VM and the target hosts
Asset criticality (client-declared, 0-100)	65 — dedicated laboratory infrastructure, no production data
Assessment type	Discovery sweep only (host and service enumeration, see Section 5.4)

The client-declared criticality values above must be supplied to the assessment framework when each target is registered, because they feed the risk-priority scoring of the findings in the final report.

3.3 Assets explicitly OUT OF SCOPE

The following are **strictly out of scope**. Any traffic, scanning, probing or enumeration directed at these systems is a breach of this agreement and must not occur:

- Any host other than the two assets named in Sections 3.1 and 3.2, including any address obtained by DNS enumeration or referenced in application responses. Hosts discovered by the Section 3.2 sweep are in this category until separately authorized.
- The virtualization host machine itself and the assessment team's own workstation connected to the laboratory network.
- The AI providers reachable through the gateway (any external model API, its endpoints, accounts or infrastructure). Only the Company's self-hosted OmniRoute instance is in scope; the upstream project's own services are not.
- JuiceBox corporate network, employee endpoints, VPN concentrators and mail servers.
- Third-party payment gateways, CDN providers, analytics or any externally hosted service.
- Any production system of the Company other than the staged gateway deployment named in Section 3.1.
- Social engineering, phishing, or any testing involving JuiceBox personnel.
- Physical security testing of any JuiceBox premises.

4. Assessment objectives

The Company requests that the assessment pursue the following objectives, in priority order:

- **4.1 Service and version discovery:** identify every network service and software version exposed by the authorized targets, using lightweight active discovery (nmap service version detection restricted to the listed ports).
- **4.2 HTTP security-header audit:** enumerate the complete set of HTTP response headers on each web target and report every missing or weakly configured browser security header (Content-Security-Policy, Strict-Transport-Security where applicable, X-Frame-Options, X-Content-Type-Options and Referrer-Policy) together with a per-header explanation and remediation.
- **4.3 Technology fingerprinting:** identify disclosed technology fingerprints (server banner, framework markers, X-Powered-By style headers) that would assist an attacker in selecting exploits, using automated fingerprinting tools.
- **4.4 Cookie and transport review:** review the security flags of any session cookie set by the gateway's dashboard, and characterise the transport-security configuration of each web target where a TLS endpoint exists.
- **4.5 Rate-limited known-vulnerability checks:** where safe template-driven checks exist (e.g. nuclei with non-invasive templates), identify publicly documented weaknesses in the web tier without exploiting them, strictly rate-limited as required by Section 5.1.
- **4.6 DNS and name characterization:** resolve and characterise the name resolution of the authorized scope identifiers, to confirm addressing and support exposure analysis.

- **4.7 Controlled verification of critical findings:** for every finding the Company must remediate before launch, verify its exploitability using the bounded proof-of-concept techniques authorized in Section 5.2, and record the verification evidence (which finding was verified, by which technique, and the exact output that proves it) so that remediation can be prioritized on demonstrated risk.
- **4.8 Findings correlation and prioritization:** consolidate all findings, remove duplicates, and rank them by severity, risk, business criticality and confidence, so that the Company can schedule remediation before launch.
- **4.9 Network segment sweep:** enumerate the live hosts and exposed services on the authorized laboratory segment (Section 3.2), strictly rate-limited, so that any unmanaged or unexpected service on the shared range is surfaced and reported per host.

5. Rules of engagement

5.1 General conduct

- Testing is restricted to the test window stated on page 1. No activity outside the window is authorized.
- Every individual command must pass the assessment team's policy review and receive explicit human approval before execution. The Company does not authorize unattended or fully automated execution.
- All activity must remain within the authorized scope identifiers listed in Section 3. Commands whose target resolves outside this scope must be refused by the framework.
- All active scanning must be rate-limited to a maximum of 30 packets or requests per second (e.g. `nmap --max-rate 30, nuclei -rl 30`), so that no target is saturated.
- The assessment team must keep a complete audit trail of every approved command, its output, exit status, duration, and the fact of human approval. This audit trail forms part of the required deliverables.

5.2 Controlled exploitation and prohibited techniques

The Company authorizes **controlled vulnerability verification** against the gateway (Section 3.1): once the assessment identifies a vulnerability, the team may verify its exploitability with bounded, non-destructive proof-of-concept techniques (for example a crafted proof-of-concept request against the verification endpoint listed in Section 3.1, or scanner-driven parameter verification), provided that the proof demonstrates the vulnerability exists and nothing more; data extraction is limited to a single benign verification record per verified flaw (such as a database banner or software version string); and every verification command passes the framework's policy review and receives explicit human approval like any other command. No verification is authorized against the lab segment (Section 3.2). The Company recognizes that the gateway is a maintained production application, so a verification attempt that demonstrates *no exploitable weakness* is a valid and expected outcome that must be recorded as such in the report.

The following remain **prohibited** without exception (non-exhaustive):

- Denial-of-service, resource exhaustion, or any action intended to degrade availability.
- Destructive testing, data deletion, or modification of application data or configuration.
- Exploitation beyond the controlled verification defined above (no payload execution beyond the proof, no privilege escalation, no data exfiltration beyond the single benign verification record per flaw).
- Brute-force, credential-stuffing, or password attacks against any authentication mechanism (a single crafted proof-of-concept credential is not a brute-force attack).
- Persistence mechanisms of any kind (web shells, scheduled jobs, modified startup files).
- File upload to, or file writing on, the target systems, including scanner flags that write output files.
- Egress of target data to any third-party or out-of-band collection server.
- Lateral movement from any authorized target to any other system.

5.3 Technique restrictions specific to the gateway (Section 3.1)

The laboratory network is shared with other assessment teams during this window. To keep packet volume low, traceroute must not be run against the gateway. All other discovery and inspection tools enumerated by the assessment framework remain authorized for this target, subject to the rate limit in Section 5.1.

5.4 Technique restrictions specific to the lab segment (Section 3.2)

The Section 3.2 authorization is for network-level discovery only. Application-layer inspection (curl, whatweb, sslscan, nuclei) must not be run against the 192.168.198.0/24 segment. A host discovered by the sweep is not authorized for any further assessment by that fact alone; a separate authorization naming the host is required first, subject to the rate limit in Section 5.1.

5.6 Incidents and escalation

If any activity causes an unintended service disruption, or if the team discovers evidence of an actual security compromise, all testing must stop immediately and the escalation contact must be notified: **Vikram Shetty — Head of IT Infrastructure, +91 98XXXXXXX (24x7)**. Work may resume only after written confirmation from the Company.

6. Expected deliverables and acceptance criteria

#	Deliverable	Acceptance criterion
1	Assessment report (HTML) covering both authorized targets, produced by the framework's reporting module.	Contains an executive summary, the analysis mode used, and prioritized findings with severity, risk score, priority score, confidence, affected endpoint, scoring breakdown, evidence, remediation and the client-declared asset criticality.
2	Complete execution audit trail.	Every approved command recorded with its raw output, exit code, duration, attempt count and human-approval record.
3	Policy-refusal evidence.	Evidence that out-of-scope and prohibited commands were refused before execution, with the policy reason shown.
4	Remediation summary for the self-hosted AI gateway.	Each finding mapped to a concrete remediation action, ordered by priority score.
5	Controlled verification evidence.	For each finding verified under Section 5.2: which finding, which technique verified it, the exact command and output that proves exploitability, and the single benign verification record extracted (if any), so remediation can be scheduled on demonstrated risk.
6	Automation-benefit statement.	A statement of the number of commands executed, the wall-clock duration of the automated assessment, and the equivalent manual effort an unaided tester would require to reach the same coverage, so the Company can evaluate the efficiency of the semi-autonomous methodology.

The Company requires that the final report clearly state the mode of analysis used (automated AI-provider analysis or the framework's deterministic local analyzer), so that the Company can weigh the findings accordingly.

7. Information handling and confidentiality

- All findings, reports, and target outputs are classified Confidential and are to be shared only between the named contacts in this document and the assessment team.
- Any API keys or credentials configured during the engagement must be stored encrypted and must never be returned in cleartext by any interface of the framework.
- The assessment team must delete all retained client data within 30 days of report acceptance, except anonymized, aggregated metrics required for academic publication.

- Any academic publication resulting from this engagement must present the environment as a laboratory deployment and must not disclose the Company's name or identifiable system details. The present document is a fictional scenario prepared for laboratory demonstration and publication purposes.

8. Client authorization and acceptance

By signing below, the Company confirms that the assets listed in Section 3 are owned or controlled by the Company and authorizes the assessment team to conduct the activities described in this document, within the stated scope, rules and time window. The assessment team accepts the rules of engagement by counter-signing.

	For the Company (client authorization)	For the assessment team (acceptance)
Name	Ananya Rao	
Role	Chief Information Security Officer	Team lead, red teaming framework
Signature		
Date	10 September 2026	

A signed copy of this authorization must be retained by both parties for the duration of the engagement and must be produced on request during the assessment.